

Information Security Policy

Policy No: POL-IT-001 | Version: v2.1 | Department: IT & Security | Effective: March 17, 2026

1. PURPOSE

This policy establishes the framework for protecting the organization's information assets, systems, and data from unauthorized access, disclosure, modification, or destruction. It ensures confidentiality, integrity, and availability of all information resources.

2. SCOPE

This policy applies to all employees, contractors, consultants, temporary staff, and any other workers at the company, including all personnel affiliated with third parties who have access to company information systems and data.

3. TABLE OF CONTENTS

Section	Title
4	Information Classification
5	Access Control
6	Network Security
7	Physical Security
8	Incident Reporting
9	Compliance & Enforcement

4. INFORMATION CLASSIFICATION

4.1 Classification Levels

All company data must be classified into one of four categories to ensure appropriate handling:

- **Public:** Information that can be freely shared with the general public (e.g., marketing materials, press releases).
- **Internal:** Information for internal use only; not to be shared outside the organization without authorization.
- **Confidential:** Sensitive business information with restricted access (e.g., financial reports, HR records, client data).
- **Restricted:** Highly sensitive information with strict need-to-know access (e.g., trade secrets, encryption keys, executive strategies).

4.2 Handling Requirements

Employees must handle data according to its classification. Confidential and Restricted data must be encrypted during transmission and storage. Physical documents containing sensitive data must be stored in locked cabinets and shredded when no longer needed.

5. ACCESS CONTROL

5.1 Principle of Least Privilege

Access to information systems and data is granted on a need-to-know basis. Employees receive only the minimum level of access required to perform their job functions.

5.2 User Account Management

- All user accounts must be uniquely identified and tied to a specific individual.
- Shared or generic accounts are strictly prohibited.
- User access must be reviewed every 90 days by department managers.
- Access must be revoked immediately upon employee termination or role change.

5.3 Multi-Factor Authentication (MFA)

MFA is mandatory for all remote access, administrative accounts, and access to systems containing Confidential or Restricted data. Employees must enroll in MFA within their first week of joining.

6. NETWORK SECURITY

6.1 Network Usage

Company network resources are for business purposes only. Employees must not attempt to bypass network security controls, intercept network traffic, or connect unauthorized devices to the corporate network.

6.2 Wireless Network

- Only authorized Wi-Fi networks may be used for company business.
- Public Wi-Fi must only be accessed through the company VPN.
- Guest networks are available for visitors and must not be used by employees for work purposes.

6.3 VPN Requirements

All remote access to company resources must use the approved VPN solution. VPN credentials must not be shared. Employees must disconnect the VPN when not actively using company resources.

7. PHYSICAL SECURITY

- All employees must wear their access badge visibly at all times while on company premises.
- Tailgating through secure doors is strictly prohibited — each person must badge in individually.
- Workstations must be locked when unattended (Win+L or Ctrl+Cmd+Q on Mac).
- Clear desk policy: No sensitive documents should be left visible on desks when stepping away.
- Visitors must sign in at reception and be escorted by a company employee at all times.

Note: Physical security violations should be reported to the Facilities & Security team immediately.

8. INCIDENT REPORTING

Any suspected or confirmed security incident must be reported to the IT Security team within 1 hour of discovery.

8.1 What to Report

- Unauthorized access to systems or data
- Lost or stolen devices (laptops, phones, badges)
- Phishing emails or suspicious communications
- Malware infections or unusual system behavior
- Data breaches or accidental disclosure of sensitive information

8.2 Reporting Channels

Report via: security@company.com | IT Helpdesk ext. 1000 | Emergency: Security hotline 1800-SEC-HELP.
Do not attempt to investigate or remediate a security incident on your own.

9. COMPLIANCE & ENFORCEMENT

Compliance with this policy is mandatory for all employees. Violations may result in disciplinary action up to and including termination of employment and legal action where applicable.

The IT Security team will conduct quarterly audits to verify compliance. Employees are required to complete annual security awareness training.

Note: This policy is reviewed annually and updated as required by changes in technology, regulations, or business needs.

ACKNOWLEDGEMENT

EMPLOYEE ACKNOWLEDGEMENT			
I, the undersigned, confirm that I have read, understood, and agree to comply with this policy. I understand that violation of this policy may result in disciplinary action.			
Employee Name:		Date:	
Employee ID:		Signature:	
Department :		Manager:	

For questions regarding this policy, contact the IT Department at it-policy@company.com